Legal aspects of IT security
Master in cybersecurity

Elise Delhaise

Academic year 2025-2026

UNIVERSITÉ DE NAMUR

Data Protection Law

UNIVERSITÉ DE NAMUR

II. General Data Protection Regulation

1. Background
2. Key Definitions
3. Scope
4. Principles
5. Rights of the data subject
6. General obligations of the controller and the processor
7. **Security of personal data**

Security of personal data

UNIVERSITÉ DE NAMUR

Summary

I. The principle of data integrity and confidentiality
II. The security obligation
III. A risk-based approach
IV. Notification and communication of data breaches

I. The principle of data integrity and confidentiality

I. The principle of data integrity and confidentiality

« *Personal data shall be :*

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures (‘integrity and confidentiality’) »

(GDPR, article 5)

I. The principle of data integrity and confidentiality

3 key elements :

1. Integrity
2. Confidentiality
3. Availability

I. The principle of data integrity and confidentiality – 1. The concept of integrity

Data integrity = « *the property that data is authentic and has not been maliciously or accidentally altered during processing, storage or transmission. The notion of integrity can be extended to IT systems and requires that the processing of personal data on these systems remains unaltered* »

(Group 29, WP 196)

I. The principle of data integrity and confidentiality – 1. The concept of integrity

Integrity breach = *“a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored or otherwise processed in connection with the provision of a publicly available electronic communications service in the Community*»

(Group 29, WP 213)

I. The principle of data integrity and confidentiality – 2. The concept of confidentiality

Data Confidentiality = « *preventing unauthorised access to or use of personal data and the equipment used for the processing* »

(GDPR, recital n° 39)

I. The principle of data integrity and confidentiality – 2. The concept of confidentiality

Confidentiality breach = « *unauthorized disclosure of, or access to, personal data*»

(Group 29, WP 213)

I. The principle of data integrity and confidentiality – 3. The concept of availability

Data availability = « *the property of information, systems and processes to be accessible and usable at the request of an authorised entity* »

(CPVP, « note relative à la sécurité des données à caractère personnel »)

II. The security obligation

UNIVERSITÉ DE NAMUR

II. The security obligation

« *Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures* to ensure a level of security appropriate to the risk*, including inter alia as appropriate :*

[…]

II. The security obligation

[…]

a) the pseudonymisation and encryption of personal data

b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;

d) a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures for ensuring the security of the processing »

(GDPR, article 32, §1er)

II. The security obligation

1. The scope of the security obligation
2. The controller and the processor
3. Appropriate security measures

II. The security obligation

1. The scope of the security obligation

Several features :

- “Modifiable” obligation

Several parameters to be taken into account in determining the extent of the obligation

- Obligation of means

Fault only if the necessary means were not implemented to avoid the fault

II. The security obligation
2. The controller and the processor

- Notions
- Responsibility for compliance with the principle of integrity and confidentiality
- Subcontracting contract

II. The security obligation
2. The controller and the processor

- **Notions**

- Responsable du traitement = « *the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data* » (GDPR, article 4, 7°)

- Sous-traitant = « *a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller* » (GDPR, article 4, 8°)

II. The security obligation
2. The controller and the processor

- **Responsibility for compliance with the principle of integrity and confidentiality**

-> Controller’s responsability

- Processing carried out by controller himself

- Processing carried out on its behalf

! Controller AND processor liable for the obligation of security

-> Joint and several liability

II. The security obligation
2. The controller and the processor

- **Subcontracting contract**

-> Guarantees required :

- « *To ensure compliance with the requirements of this Regulation in respect of the processing to be carried out by the processor on behalf of the controller, when entrusting a processor with processing activities, the controller should use only processors providing sufficient guarantees, in particular in terms of expert knowledge, reliability and resources, to implement technical and organisational measures* » (GDPR, recital n° 81)

- Contractual provisions detailed in the contract (GDPR, article 28, §3, f and h)

II. The security obligation
3. Appropriate security measures

A. The information security policy
B. The nature, scope, context and purposes of the processing
C. The risks
D. The state of knowledge
E. Implementation costs
F. (Codes of conduct, certifications, labels and brands)

II. The security obligation
3. Appropriate security measures – A. The information security policy

-> DPA recommendation

"*Any organisation processing personal data must draw up a written document (=information security policy) specifying the strategies and measures adopted to secure such data*":

- Risk assessment approach
- Priorities selected and mechanisms implemented or to be implemented following analysis
- Implementation schedule
- Responsibilities and organisational rules put in place
- Security incident management process
- Awareness-raising process
- Updating the security system

II. The security obligation
3. Appropriate security measures – B. The nature, scope, context and purposes of the processing

-> See previous lessons about data protection

II. The security obligation

3. Appropriate security measures – C. The risks

-> See III. A « risk-based approach »

II. The security obligation
3. Appropriate security measures – D. The state of knowledge

- Obligation to keep abreast of the various safety techniques available on the market
- Consideration of state-of-the-art methods and techniques
- Evaluation of methods and techniques identified

! Does not release the data controller from his obligation of security

Sufficient and reasonable costs

If it is impossible to provide sufficient guarantees :

- Waiver of processing

OR

- Prior consultation of the supervisory authority

III. A « risk-based approach »

III. A « risk-based approach »

« […] to ensure a level of security appropriate to the risk[…] » (GDPR, article 32, §1er)

Evolutionary and proportional approach

-> The higher the risk, the greater the number of security measures required

III. A « risk-based approach »

1. The concept of risk
2. Risk analysis
3. Data Protection Impact Assessment (DPIA)

III. A « risk-based approach »
1. The concept of risk

Risk = « *the possibility of negative consequences for the fundamental rights and freedoms of natural persons, resulting from the accidental or unlawful processing of personal data* » (Group 29, WP 248)

What fundamental rights and freedoms?

III. A « risk-based approach »
1. The concept of risk

Distinction :

- Inherent risk
- Residual risk

III. A « risk-based approach »
1. The concept of risk

« Risk-based approach » : variable geometry risk

2 variables :

A. The probability of the risk
B. The severity of the risk

III. A « risk-based approach »
1. The concept of risk – A. The probability

= analyse the potential recurrence of a possible event

Methodology based on 4 dimensions (ENISA):

- Technical and network resources
- Processes and procedures governing processing
- Various external and internal recipients involved in processing
- Sector concerned and scale of processing

III. A « risk-based approach »
1. The concept of risk – B. The severity

Seriousness linked to the potential damage (physical, material, moral) caused by the risk

- ✓ discrimination, identity theft or usurpation, financial loss, damage to reputation, loss of confidentiality of data protected by professional secrecy, unauthorised reversal of the pseudonymisation process or any other significant economic or social damage (GDPR, Recital 75)
- ✓ Loss of opportunity, harm to tranquillity or well-being, stigmatisation or stereotyping, refusal or restriction of access to places or events, unfair treatment, manipulation, adaptation of behaviour, harm to physical or moral integrity (DPA, Recommendation No. 01/2018)

III. A « risk-based approach »
2. Risk analysis

« *In order to guarantee security and prevent any processing carried out in breach of this Regulation, it is important that the controller or processor assess the risks inherent in the processing* […]» (RGPD, considérant n° 83)

! Obligation for all processing operations, not just those likely to give rise to a high risk

III. A « risk-based approach »
2. Risk analysis

Risk analysis = 3-step process

- Risk identification

= Examine, recognise and describe

- Risk analysis

= Understand the nature of the risk and determine the level of risk

- Risk assessment

= Determine whether the risk is acceptable

(APD, Recommendation n° 01/2018)

III. A « risk-based approach »
2. Risk analysis

2 questions (APD, Recommendation n° 01/2018):

- What is the scale of the potential impact on those affected?
- What is the likelihood of this impact occurring?

-> Risk severity and probability

III. A « risk-based approach »
2. L’analyse du risque

Free evaluation method

BUT it must :

- Be objective
- Be justified in relation to another method
- Be methodologically supported
- Be adapted to the context and profile of the debtor of the obligationbe legible and accessiblebe structured
- Be nuanced

(APD, Recommendation n° 01/2018)dation n° 01/2018)

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

Mandatory in cases of "high risk

= data processing which is or could be likely to have an adverse effect on the fundamental rights and freedoms of natural persons

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

Several categories of processing are covered:

- where the processing uses biometric data for the unique identification of data subjects in a public place or in a private place accessible to the public;
- where personal data is collected from third parties for the purpose of being taken into account in deciding whether to refuse or terminate a specific service contract with a natural person;

[…]

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- when a data subject's health data is collected by automated means using an active implantable medical device;
- when data is collected on a large scale from third parties in order to analyse or predict the economic situation, health, personal preferences or interests, reliability or behaviour, location or movements of individuals;

[…]

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- where special categories of personal data within the meaning of Article 9 of the GDPR or data of a very personal nature are exchanged systematically between several data controllers;
- where there is large-scale processing of data generated by means of devices equipped with sensors which send data via the Internet or another means, and where this processing serves to analyse or predict the economic situation, health, personal preferences or interests, reliability or behaviour, location or movements of natural persons
- […]

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- where there is a question of large-scale and/or systematic processing of telephony, Internet or other communication data, metadata or location data relating to natural persons or making it possible to lead to natural persons where the processing is not strictly necessary for a service requested by the data subject

[…]

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- where large-scale processing of personal data is involved in which the behaviour of natural persons is observed, collected, established or influenced, including for advertising purposes, on a systematic basis by means of automated processing

-> Evolving list

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- **Essential elements of an AIPD**

"The assessment shall contain at least:

(a) a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the controller;

(b) an assessment of the necessity and proportionality of the processing operations in relation to the purposes;

(c) an assessment of the risks to the rights and freedoms of data subjects referred to in paragraph 1; and

(d) the measures envisaged to address the risks, including safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with this Regulation taking into account the rights and legitimate interests of data subjects and other persons concerned" (GDPR, art. 35, §7).

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- **Essential elements of a DPIA**

- Description of the processing operations envisaged
- Necessity and proportionality check
- Risk assessment
- Prior consultation of the supervisory authority

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- **Essential elements of a DPIA**

- Description of the processing operations envisaged

At least the following elements (Group 29, WP 248): clear description of the processing, personal data, recipients and storage period and assets on which the personal data are based

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- **Essential elements of an DPIA**

- Necessity and proportionality check

For what reason(s) is the processing necessary?

For what reason(s) is (are) each of the processing operations necessary to achieve the intended purpose(s)?

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- **Essential elements of an DPIA**

- Risk assessment

For high risks

BUT

DPA recommendation: map all risks

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

- **Essential elements of an DPIA**

- Prior consultation of the supervisory authority

Mandatory only in cases of high residual risk

III. A « risk-based approach »
3. Data Protection Impact Assessment (DPIA)

Role of the various players

- Data controller
- Processor
- Data Protection Officer
- Data subjects

IV. Notification and communication of data breaches

IV. Notification and communication of data breaches

1. Preliminary concepts
2. Time limits
3. Violations that need not be notified/communicated
4. Content of the notification/communication

IV. Notification and communication of data breaches

"*In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Where the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay*" (GPRD, art. 33, §1)

IV. Notification and communication of data breaches
1. Preliminary concepts

A. Data breach

B. Notification vs communication

IV. Notification and communication of data breaches
1. Preliminary concepts – A. data breach

personal data breach = "*a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed*" (GDPR, art. 4, 12°)

-> Notions of integrity, confidentiality and availability

Notification -> supervisory authority

Communication -> data subject

IV. Notification and communication of data breaches
2. Time limits

- Data controller: as soon as possible, if possible within 72 hours of becoming aware*

- Processor : as soon as possible after becoming aware*.

IV. Notification and communication of data breaches
2. Time limits

Starting point of the time limit: knowledge of the breach

= the moment when there is a "reasonable degree of certainty" that a breach has occurred and that the data has been compromised

IV. Notification and communication of data breaches
3. Violations that need not be notified/communicated

Prerequisite: is the breach likely to result in a high risk for the data subjects?

-> Consequences of the actual materialisation of the risk following the data breach

! ≠ risk assessment as part of a DPIA

IV. Notification and communication of data breaches
3. Violations that need not be notified/communicated

- Non-notifiable breaches: breaches that are unlikely to give rise to a risk to the rights and freedoms of natural persons.

- Non-communicable breaches*: breaches likely to give rise to a high risk for the rights and freedoms of an individual

- Non- communicable breaches*:

"The communication to the data subject referred to in paragraph 1 shall not be required if any of the following conditions are met:

(a) the controller has implemented appropriate technical and organisational protection measures, and those measures were applied to the personal data affected by the personal data breach, in particular those that render the personal data unintelligible to any person who is not authorised to access it, such as encryption;

[…]

IV. Notification and communication of data breaches
3. Violations that need not be notified/communicated

- Non- communicable breaches*:

[…]

b) the controller has taken subsequent measures which ensure that the high risk to the rights and freedoms of data subjects referred to in paragraph 1 is no longer likely to materialise;

(c) it would involve disproportionate effort. In such a case, there shall instead be a public communication or similar measure whereby the data subjects are informed in an equally effective manner" (GDPR, art. 34, §3)

IV. Notification and communication of data breaches
4. Content of the notification/communication

"*The <u>notification</u> referred to in paragraph 1 shall at least:*

(a) describe the nature of the personal data breach including where possible, the categories and approximate number of data subjects concerned and the categories and approximate number of personal data records concerned;

(b) communicate the name and contact details of the data protection officer or other contact point where more information can be obtained;

(c) describe the likely consequences of the personal data breach;

(d) describe the measures taken or proposed to be taken by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects" (GDPR, art. 33, §3)

IV. Notification and communication of data breaches
4. Content of the notification/communication

"*The communication to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and contain at least the information and measures referred to in points (b), (c) and (d) of Article 33(3)*" (GDPR, art. 34, §2).

Objective: to enable those concerned to take appropriate action

IV. Notification and communication of data breaches
4. Content of the notification/communication

Direct communication with the persons concerned EXCEPT if disproportionate efforts are made

As soon as possible

Any questions ?

Thanks for your attention !

UNIVERSITÉ DE NAMUR